

Web Application Vulnerability Assessment & Penetration Testing Report

05-March-2026

Scope URL - <https://smclama.smcindiaonline.com/>

Tested By - InfoSec

S. No.	Vulnerabilities	Severity
1.	Information Disclosure Internal Windows Server Details	High
2.	Privilege Escalation	High
3.	Insecure Direct Object References (IDOR)	High
4.	Weak Authentication Login Page Bypass	High
5.	Insecure Data Storage	High
6.	Improper Input Validation	Medium
7.	Security Misconfiguration	Low
8.	Banner Grabbing	Low

1. Information Disclosure Internal Windows Server Details

Severity - High

Description - This is a security problem where important details about a company's private computer/server are openly available on the internet to anyone — without needing a password or login. In your case:

This is a security problem where important details about a company's private computer/server are openly available on the internet to anyone — without needing a password or login.

- You can see the server's name ("DR-SMC-LOCAL-ODIN-MANAGER")
- Its private IP address (192.168.176.103 — this should never be visible outside the company)
- It runs Windows Server 2019
- How much CPU, memory, disk space it uses
- How long it has been running (uptime)
- Other health numbers (like network speed, last seen time)

This data comes from an internal monitoring tool/agent that checks server health. Normally, only company employees (inside their private network) should see this. But right now, it's public — like leaving your house keys and address on the street for strangers.

This data comes from an internal monitoring tool/agent that checks server health. Normally, only company employees (inside their private network) should see this. But right now, it's public — like leaving your house keys and address on the street for strangers.

Impact — Even though it looks like "just numbers and names", attackers can use this info in dangerous ways:

- Recon / Spying — Attackers learn the company's internal setup: which machines exist, what OS/version they use, how busy they are. This helps plan bigger attacks.
- Targeted Attacks — Knowing exact hostname + OS version + uptime helps find known bugs (vulnerabilities) in Windows Server 2019 that might not be patched. They can search for exploits online.
- Phishing or Social Engineering — They can pretend to be IT support: "Hi, we saw your DR-SMC-LOCAL-ODIN-MANAGER server has high disk usage — click this link to fix". Easier to trick employees.
- Network Mapping — Private IP + machine name gives clues about the company's internal network layout. If another small mistake exists (like weak firewall), attackers might try to enter.
- Regulatory Trouble — SMC is a stock broking company (regulated by SEBI in India). Exposing internal trading-related server info (ODIN Manager is for trading software) can break rules and cause fines or bad reputation.
-

Mitigation —

Add Authentication — Put a strong login (username + password, or better: API key / token) on this monitoring page/endpoint. No one should see it without logging in.

Block Public Access — Put the page behind a firewall or VPN (only company network or approved IPs can reach it).

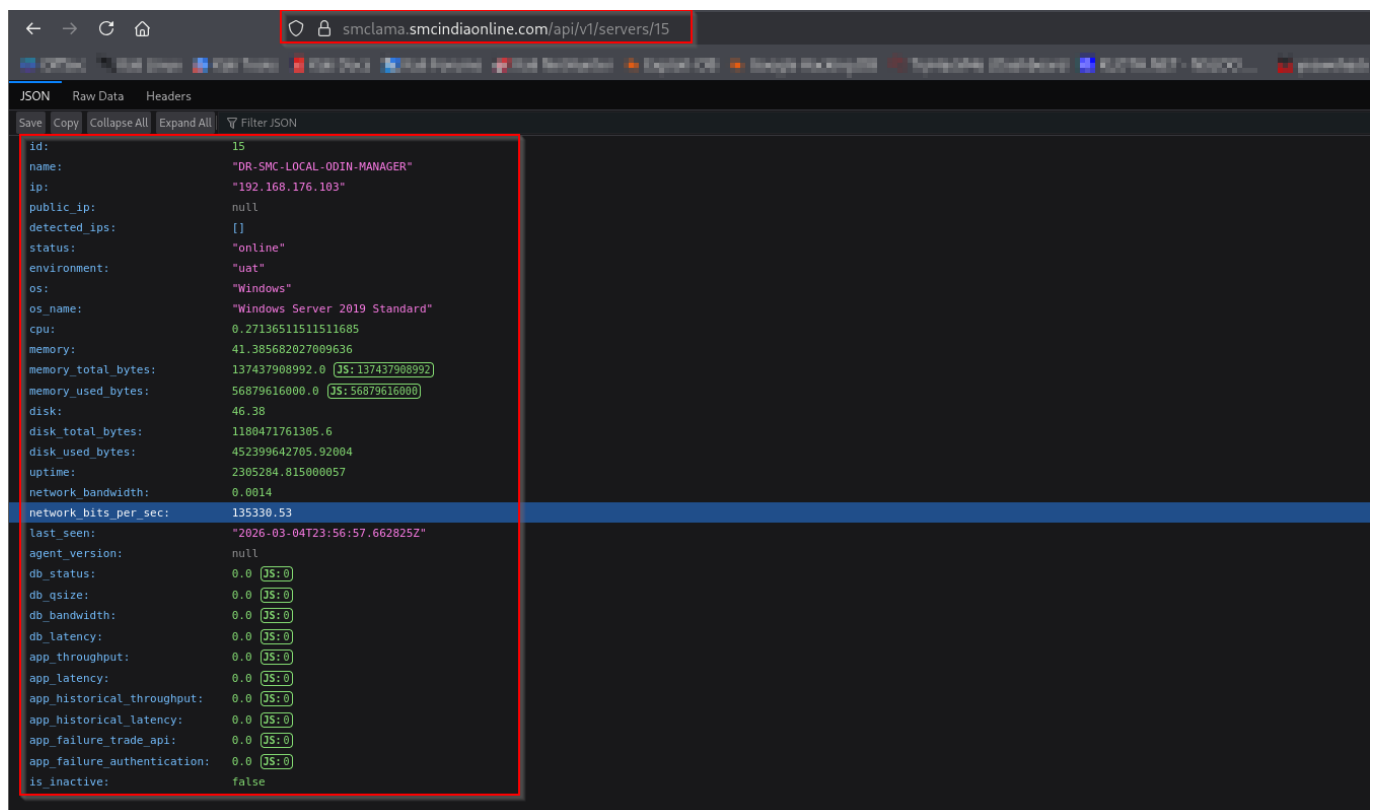
- use "IP whitelisting" — only allow access from company offices/VPN.

Remove or Hide Sensitive Details — In the monitoring tool: Don't show private IPs, exact hostnames, or full OS versions to outsiders. Show only basic info (like "Server online" without numbers).

Check Configuration — Find where this data is coming from (maybe Prometheus, Zabbix, custom agent, or ODIN software dashboard).

- Make sure it's not accidentally set to "public" mode.
- Disable any debug or test endpoints that leak info.

Proof-of-concept -



Screenshot 1.1

smclama.smcindiaonline.com/api/v1/servers/16

JSON Raw Data Headers

Save Copy Collapse All Expand All Filter JSON

```
{
  "id": 16,
  "name": "DR-SMC-ODIN4-ODIN-MANAGER",
  "ip": "192.168.176.104",
  "public_ip": null,
  "detected_ips": [],
  "status": "online",
  "environment": "uat",
  "os": "Windows",
  "os_name": "Windows Server 2019 Standard",
  "cpu": 11.103515625,
  "memory": 41.79714495754135,
  "memory_total_bytes": 137437908992.0 (JS: 137437908992),
  "memory_used_bytes": 57354760192.0 (JS: 57354760192),
  "disk": 49.03,
  "disk_total_bytes": 1180471761305.6,
  "disk_used_bytes": 452818402017.27997,
  "uptime": 56521.09700012207,
  "network_bandwidth": 0.2975,
  "network_bits_per_sec": 29749732.8,
  "last_seen": "2026-03-05T00:03:48.897369Z",
  "agent_version": null,
  "db_status": 0.0 (JS: 0),
  "db_qsize": 0.0 (JS: 0),
  "db_bandwidth": 0.0 (JS: 0),
  "db_latency": 0.0 (JS: 0),
  "app_throughput": 0.0 (JS: 0),
  "app_latency": 0.0 (JS: 0),
  "app_historical_throughput": 0.0 (JS: 0),
  "app_historical_latency": 0.0 (JS: 0),
  "app_failure_trade_opi": 0.0 (JS: 0),
  "app_failure_authentication": 0.0 (JS: 0),
  "is_inactive": false
}
```

Screenshot 1.2

smclama.smcindiaonline.com/api/v1/servers/1

JSON Raw Data Headers

Save Copy Collapse All Expand All Filter JSON

```
{
  id: 1,
  name: "SMCXTSDB",
  ip: "192.168.1.22",
  public_ip: null,
  detected_ips: [],
  status: "online",
  environment: "uat",
  os: "Linux",
  os_name: "Ubuntu 22.04.5 LTS",
  cpu: 2.7749999999832653,
  memory: 32.83730074111838,
  memory_total_bytes: 33614995456.0 JS: 33614995456,
  memory_used_bytes: 11038257152.0 JS: 11038257152,
  disk: 21.74,
  disk_total_bytes: 524501406187.52,
  disk_used_bytes: 114052856545.28,
  uptime: 64458.50600004196,
  network_bandwidth: 0.1398,
  network_bits_per_sec: 13981155.2,
  last_seen: "2026-03-05T00:04:58.904123Z",
  agent_version: null,
  db_status: 0.0 JS: 0,
  db_qsize: 0.0 JS: 0,
  db_bandwidth: 0.0 JS: 0,
  db_latency: 0.0 JS: 0,
  app_throughput: 0.0 JS: 0,
  app_latency: 0.0 JS: 0,
  app_historical_throughput: 0.0 JS: 0,
  app_historical_latency: 0.0 JS: 0,
  app_failure_trade_api: 0.0 JS: 0,
  app_failure_authentication: 0.0 JS: 0,
  is_inactive: false
}
```

Screenshot 1.3

2. Privilege Escalation.

Severity - **High**

Description - Privilege Escalation is a security issue where a user is able to perform actions or access resources that they are not supposed to access. This happens when the application does not properly check the user's permissions. As a result, a normal user may gain higher privileges (such as admin access) by manipulating requests, parameters, or URLs.

Impact –

- A normal user may gain administrator or higher-level access.
- Attackers can view, modify, or delete sensitive data.
- Unauthorized actions may be performed on other users' accounts.
- It can lead to full system compromise if admin privileges are obtained.

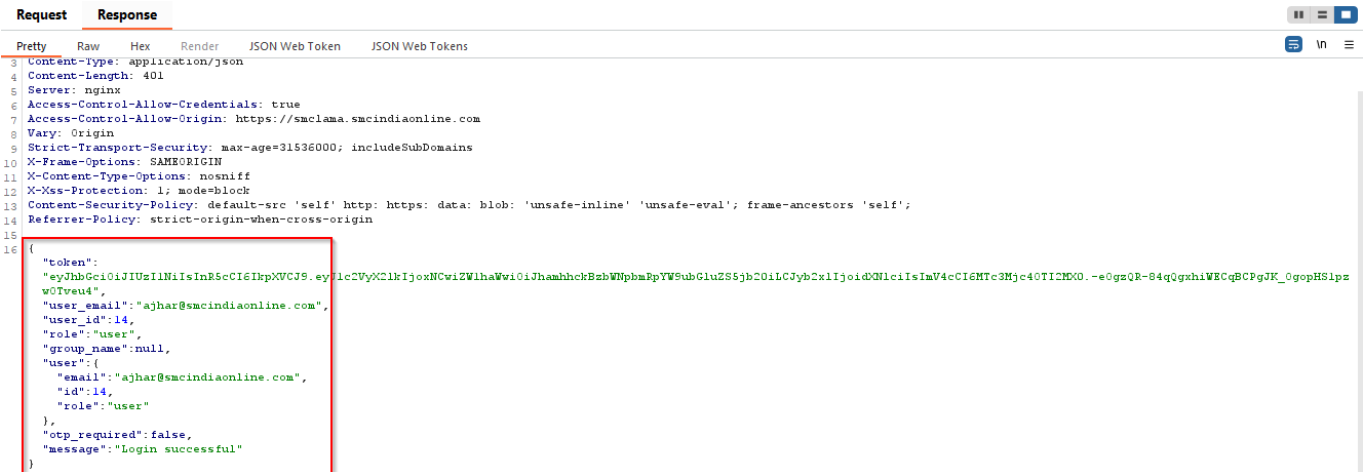
Mitigation –

- Implement proper access control checks on the server side for every request.
- Ensure users can only access resources that belong to their assigned role (e.g., user, admin).
- Use role-based access control (RBAC) or similar permission management systems.
- Validate user permissions before performing sensitive actions.
- Regularly test and review authorization logic to ensure no privilege bypass is possible.

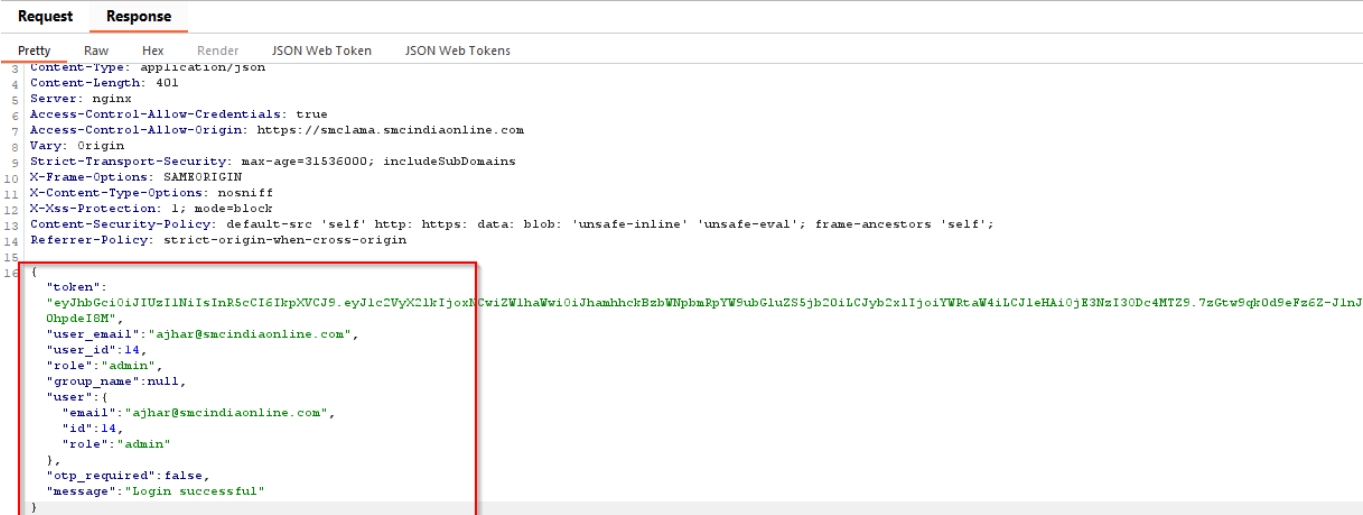
Proof-of-concept –

The screenshot displays the SMC-LAMA web application interface. The browser address bar shows the URL `smclama.smcindiaonline.com/users`. The application header includes the SMC logo, the text "SMC-LAMA", and a user profile section with a "UAT" badge and the email `ajhar@smcindiaonline.com (user)`. The main content area is titled "User Management" and includes a sub-header "Read-only access - Admin required for modifications". A red error message box states: "Error loading users: Access denied. Admin role required to perform this action." Below this, the "All Users" section shows "Total: 0 users" and a table with columns: Email, Mobile, Full Name, Role, and Created. The table is empty, displaying "No users found". The left sidebar contains navigation links for "LAMA Management", "Environment", "ALERTS", "ADMINISTRATION", and "Users". The footer indicates the version "SMC-LAMA v1.0.52".

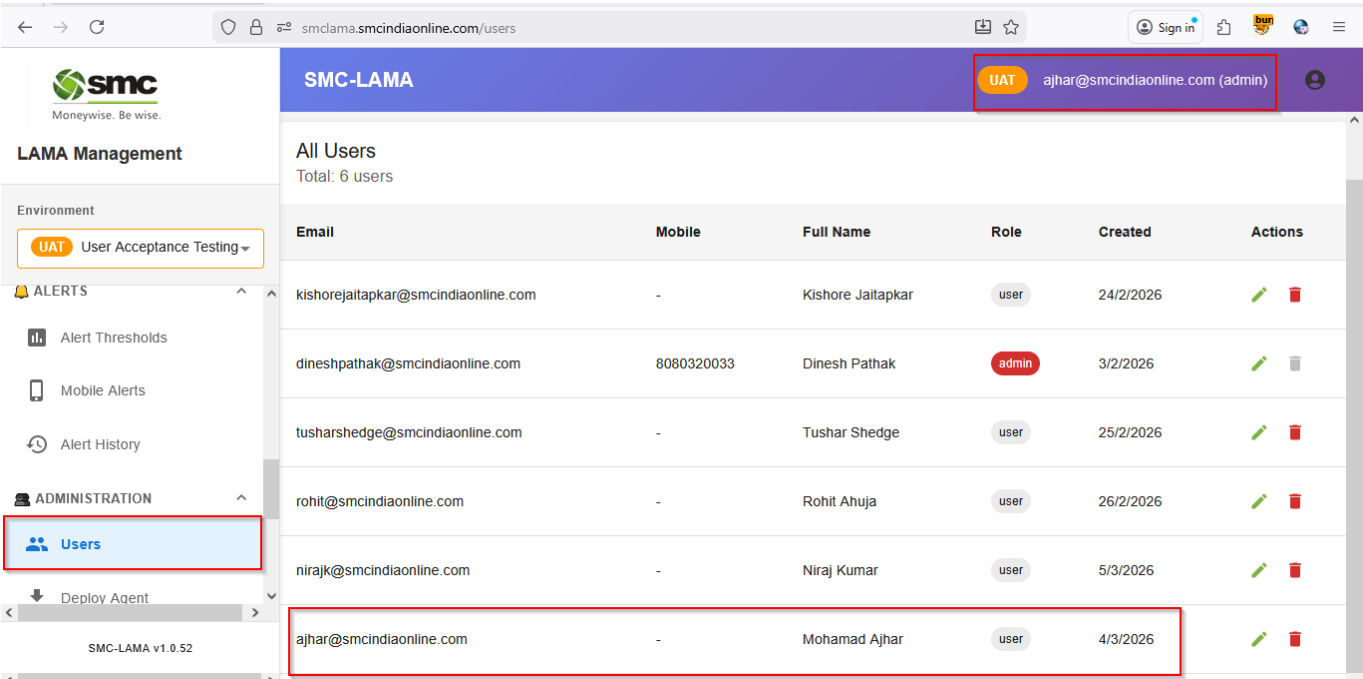
Screenshot 2.1



Screenshot 2.2



Screenshot 2.3



Screenshot 2.4

3. Insecure Direct Object References (IDOR).

Severity - High

Description - Insecure Direct Object Reference (IDOR) is a vulnerability that occurs when an application allows users to access or modify data by changing a direct identifier such as user ID, order ID, file ID, or account number in the request (URL, parameter, or API call), without properly checking whether the user has permission to access that data.

Because the application does not verify ownership or authorization, an attacker can manipulate these identifiers to view or interact with other users' data.

Impact –

- Attackers may view sensitive information of other users (such as personal details, orders, or documents).
- Unauthorized users may modify or delete other users' data.
- It may lead to account takeover or financial fraud if critical actions are exposed.
- Large amounts of user data could be exposed through automated enumeration of IDs.

Mitigation –

- Implement proper authorization checks on the server side for every request.
- Ensure the application verifies that the requested resource belongs to the logged-in user.
- Avoid exposing predictable identifiers such as sequential IDs; use random or UUID identifiers when possible.
- Apply access control mechanisms like Role-Based Access Control (RBAC).
- Regularly perform security testing and code reviews to detect unauthorized access issues.

Proof-of-concept -

3. Intruder attack of https://smclama.smcindiaonline.com

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload	Status code ^v	Response received	Error	Timeout	Length	Comment
1	1	200	173			631	
8	8	200	275			630	
10	10	200	195			623	
11	11	200	200			614	
14	14	200	310			616	
0		404	173			489	
2	2	404	172			489	
3	3	404	275			489	
4	4	404	271			489	

Request Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Wed, 04 Mar 2026 08:32:43 GMT
3 Content-Type: application/json
4 Content-Length: 175
5 Server: nginx
6 Strict-Transport-Security: max-age=31536000; includeSubDomains
7 X-Frame-Options: SAMEORIGIN
8 X-Content-Type-Options: nosniff
9 X-Xss-Protection: 1; mode=block
10 Content-Security-Policy: default-src 'self' http: https: data: blob: 'unsafe-inline' 'unsafe-eval'; frame-ancestors 'self';
11 Referrer-Policy: strict-origin-when-cross-origin
12
13 {
14   "id":1,
15   "email":"dineshpathak@smcindiaonline.com",
16   "mobile":"8080320033",
17   "full_name":"Dinesh Pathak",
18   "role":"admin",
19   "is_active":true,
20   "created_at":"2026-02-02T20:05:00.935598Z"
21 }
```

Screenshot 3.1

Results Positions

Request	Response
1	200 OK
2	200 OK
3	200 OK
4	200 OK
5	200 OK
6	200 OK
7	200 OK
8	200 OK
9	200 OK
10	200 OK
11	200 OK
12	200 OK
13	200 OK
14	200 OK
15	200 OK
16	200 OK
17	200 OK
18	200 OK
19	200 OK
20	200 OK
21	200 OK
22	200 OK
23	200 OK
24	200 OK
25	200 OK
26	200 OK
27	200 OK
28	200 OK
29	200 OK
30	200 OK
31	200 OK
32	200 OK
33	200 OK
34	200 OK
35	200 OK
36	200 OK
37	200 OK
38	200 OK
39	200 OK
40	200 OK
41	200 OK
42	200 OK
43	200 OK
44	200 OK
45	200 OK
46	200 OK
47	200 OK
48	200 OK
49	200 OK
50	200 OK
51	200 OK
52	200 OK
53	200 OK
54	200 OK
55	200 OK
56	200 OK
57	200 OK
58	200 OK
59	200 OK
60	200 OK
61	200 OK
62	200 OK
63	200 OK
64	200 OK
65	200 OK
66	200 OK
67	200 OK
68	200 OK
69	200 OK
70	200 OK
71	200 OK
72	200 OK
73	200 OK
74	200 OK
75	200 OK
76	200 OK
77	200 OK
78	200 OK
79	200 OK
80	200 OK
81	200 OK
82	200 OK
83	200 OK
84	200 OK
85	200 OK
86	200 OK
87	200 OK
88	200 OK
89	200 OK
90	200 OK
91	200 OK
92	200 OK
93	200 OK
94	200 OK
95	200 OK
96	200 OK
97	200 OK
98	200 OK
99	200 OK
100	200 OK

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Wed, 04 Mar 2026 08:32:45 GMT
3 Content-Type: application/json
4 Content-Length: 174
5 Server: nginx
6 Strict-Transport-Security: max-age=31536000; includeSubDomains
7 X-Frame-Options: SAMEORIGIN
8 X-Content-Type-Options: nosniff
9 X-Xss-Protection: 1; mode=block
10 Content-Security-Policy: default-src 'self' http: https: data: blob: 'unsafe-inline' 'unsafe-eval'; frame-ancestors 'self';
11 Referrer-Policy: strict-origin-when-cross-origin
```

```
{
  "id":8,
  "email":"kishorejaitapkar@smcindiaonline.com",
  "mobile":null,
  "full_name":"Kishore Jaitapkar",
  "role":"user",
  "is_active":true,
  "created_at":"2026-02-24T05:00:52.370442Z"
}
```



Screenshot 3.2

The screenshot shows the Burp Suite interface with the 'Response' tab selected. The target URL is 'https://smclama.smcindiaonline.com'. The response is an HTTP 200 OK status with a 'Content-Type' of 'application/json'. The JSON body contains the following data:

```
{
  "id": 10,
  "email": "tusharshedge@smcindiaonline.com",
  "mobile": null,
  "full_name": "Tushar Shedge",
  "role": "user",
  "is_active": true,
  "created_at": "2026-02-25T04:20:04.525375Z"
}
```

Screenshot 3.3

4. Weak Authentication Login Page Bypass.

Severity - High

Description - Login Page Bypass occurs when an attacker can bypass the normal login verification process and gain access to the application without proper authentication. This usually happens when the application does not correctly validate login requests on the server side. By intercepting and modifying the login request (for example using a proxy tool), an attacker may manipulate parameters or responses and gain access to protected areas of the application without providing valid credentials.

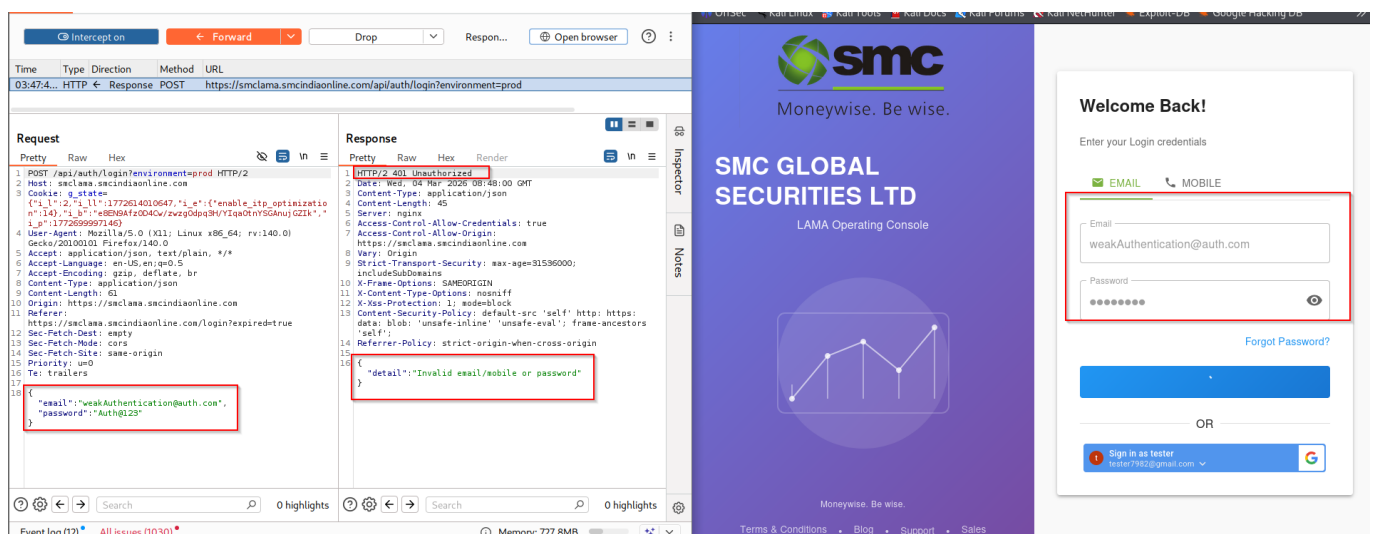
Impact –

- Attackers may access the application without valid login credentials.
- Unauthorized users may view or modify sensitive information.
- It may lead to account takeover or privilege misuse.
- Sensitive business data and user information may be exposed.

Mitigation –

- Ensure strong server-side authentication validation for every login request.
- Do not rely on client-side validation to verify user authentication.
- Implement secure session management and verify authentication status before granting access.
- Apply multi-factor authentication (MFA) for additional security.

Proof-of-concept -



Screenshot 4.1



Moneywise. Be wise.

LAMA Management

Environment

PROD Production

MONITORING

Dashboard

LAMA Monitor

Servers

Exchange Activity

Database Monitoring

Application Monitoring

CONFIGURATION

SMC-LAMA v1.0.51

SMC-LAMA

PROD

undefined (undefined)

My Profile

Profile Information

EDIT

Email Address

Email cannot be changed

Full Name

Mobile Number

Role

Contact admin to change role

Member Since

Security

CHANGE PASSWORD

LOGOUT

Screenshot 4.4

5. Insecure Data Storage.

Severity - **High**

Description - Insecure Data Storage occurs when an application stores sensitive information in an unsafe location or without proper protection. This can include storing sensitive data such as user IDs, personal details, tokens, device information, or passwords in places like local storage, cookies, files, or databases without encryption or proper security controls. If this data is accessed by attackers, it may lead to unauthorized use or data leakage.

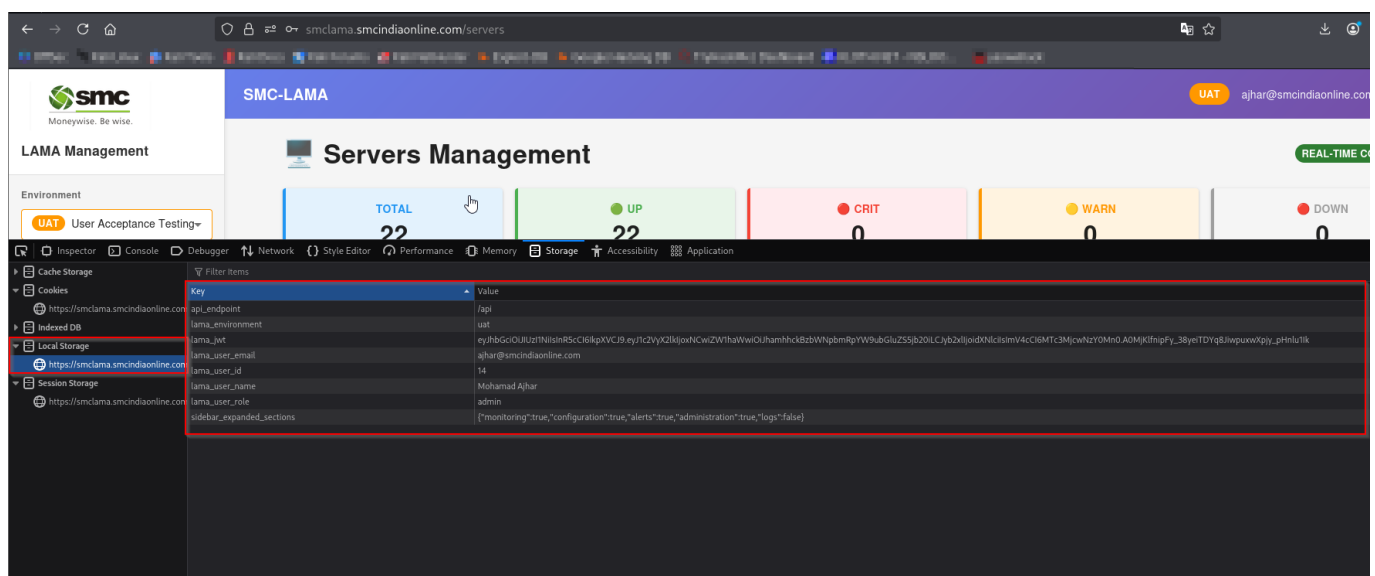
Impact –

- Sensitive information exposure, such as personal or account details.
- Attackers may steal stored data and misuse it.
- It can lead to account takeover or identity theft.
- May cause privacy violations and compliance issues with security standards.

Mitigation –

- Avoid storing sensitive data on the client side (such as in local storage or cookies).
- Store sensitive information securely on the server side.
- Use strong encryption to protect sensitive data at rest.
- Apply secure cookie attributes such as HttpOnly, Secure, and SameSite.

Proof-of-concept -



Screenshot 5.1

6. Improper Input Validation.

Severity - **Medium**

Description - During testing, it was observed that the application does not properly validate or sanitize user-supplied input received through the request path. Malicious input containing HTML/JavaScript code was accepted and directly reflected in the server response, including within redirect behaviour and response content. This indicates that the application processes untrusted input without validation or encoding, leading to improper input handling.

Impact –

- Allows attackers to inject malicious scripts into application responses.
- Can result in Reflected Cross-Site Scripting (XSS) attacks.
- Enables execution of arbitrary JavaScript in a user's browser.
- May lead to session hijacking, credential theft, phishing, or unauthorized actions.
- Weak input validation increases the likelihood of further injection-based attacks.

Mitigation –

- Implement **strict server-side input validation** for all user-controlled input, including URL paths and parameters.
- Reject or sanitize unexpected characters and script-related payloads.
- Apply **context-aware output encoding** before reflecting any user input in responses.
- Avoid reflecting raw input in redirects, headers, or response bodies.
- Implement a strong **Content Security Policy (CSP)** to reduce the impact of script injection.

Proof-of-concept -

The screenshot shows the SMC-LAMA web application interface. The 'Servers' tab is selected, displaying a table of server information. A red box highlights the input field for the 'Servers' tab, showing the malicious payload: `<img src=x onerror=alert(1)>`.

Server Name	OS	IP	Status	CPU	Mem	Net	Uptime
Odin4Svr	Windows Server 2019 Standard	192.168.1.30	ONLINE	10.5%	62.8 / 128.0 GB	1149.4 GB	45.20 Mbps 8h 33m
SmcOdinWebSvr1	Microsoft Windows Server 2019 Standard	192.168.1.183	ONLINE	2.7%	23.1 / 96.0 GB	252.7 / 949.4 GB	9.08 Mbps 8h 36m
SMCPGSvr	Microsoft Windows Server 2019 Standard	192.168.1.182	ONLINE	0.2%	2.2 / 32.0 GB	70.7 / 699.4 GB	0.10 Mbps 7h 41m
SMCXTSDB	Ubuntu 22.04.5 LTS	192.168.1.22	ONLINE	37.0%	10.6 / 31.3 GB	106.1 / 488.5 GB	73.85 Mbps 7h 54m
"	Windows	127.0.0.1	OFFLINE	0.0%	0.0%	0.0%	0 Mbps N/A

Screenshot 6.1

7. Security Misconfiguration.

Severity - **Medium**

Description - Unable to render this definition. The provided definition does not specify a valid version field. Supported version fields are swagger: "2.0" and openapi: 3.0.x, openapi: 3.1.x, or openapi: 3.2.x..." This happens because the OpenAPI/Swagger JSON or YAML file (probably loaded from /api/docs.json or similar) is missing the required "openapi" or "swagger" version field at the beginning. Because of this, the documentation page does not load properly and shows a red error box instead of the list of API endpoints.

Impact –

- Normal users or attackers cannot see the API documentation in a readable way.
- Exposes internal API structure to the public unnecessarily.

Mitigation –

Open the backend OpenAPI/Swagger file (JSON or YAML).

Add the correct version line at the very top. Example for OpenAPI 3:

```
openapi: 3.0.0
info:
  title: Your API Title
  version: 1.0.0
...
```

Or for older Swagger 2:

```
swagger: "2.0"
info:
  title: Your API Title
  version: 1.0.0
```

Proof-of-concept -



Unable to render this definition

The provided definition does not specify a valid version field.

Please indicate a valid Swagger or OpenAPI version field. Supported version fields are swagger: "2.0" and openapi: 3.0.x, openapi: 3.1.x, or openapi: 3.2.x (for example, openapi: 3.2.0).

8. Banner Grabbing.

Severity - Low

Description - Banner grabbing is a technique used by attackers to obtain information about a target system, such as the type and version of software running on a server. It involves making requests to a service and analyzing the banners or headers returned in the responses. Banners often contain information about the server software, its version, and sometimes other details that can be used by attackers to identify potential vulnerabilities.

Impact –

- **Information Disclosure:** Banner grabbing can reveal information about the server's configuration, potentially disclosing sensitive details that could aid in crafting more targeted attacks.

Mitigation –

- **Remove Unnecessary Services:** Disable or remove unnecessary services and features to minimize the attack surface and reduce the information available to potential attackers.

Proof-of-concept -

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre>1 TRACE /dashboard HTTP/2 2 Host: cn3p65txi0taiyqgl4nrv55ncei56zuo.oastify.com 3 Cookie: g_state={"i_l":1,"i_ll":"1772648657465","i_e":{"enable_itp_optimization":14}} 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Upgrade-Insecure-Requests: 1 9 Sec-Fetch-Dest: document 10 Sec-Fetch-Mode: navigate 11 Sec-Fetch-Site: none 12 Sec-Fetch-User: ?1 13 Priority: u=0, i 14 Te: trailers 15 16</pre>				<pre>1 HTTP/2 405 Method Not Allowed 2 Server: awselb/2.0 3 Date: Wed, 04 Mar 2026 18:42:39 GMT 4 Content-Type: text/html 5 Content-Length: 122 6 7 <html> 8 <head> 9 <title> 10 405 Not Allowed 11 </title> 12 </head> 13 <body> 14 <center> 15 <h1> 16 405 Not Allowed 17 </h1> 18 </center> 19 </body> 20 </html></pre>			

Screenshot 8.1